

Bug Report — Member 3 (23127185)

Sinh viên: Mai Thị Kim Duyên — MSSV 23127185 — Branch melyn

Repository: <https://github.com/HCMUS-software-testing/HW06>

SUT: EShop backend <http://localhost:3000> (seed lại bằng `node database.js` trước mỗi run)

Evidence chính: [newman/member-3/bug-discovery-report.html](#) (Bug Discovery Suite — 86 requests, 69 assertion failures, 0 script errors)

Oracle: `eshop-sut/api_specification.md` + SRS. Assertion trong suite Discovery bám **spec**, không bám hành vi SUT.

Quy ước severity: **Critical** (mất tiền / leo quyền / bypass kiểm soát) · **High** (sai logic nghiệp vụ nghiêm trọng) · **Medium** (validation yếu, lỗi UX/API contract) · **Low**.

BUG-M3-001 — FR-01: Đăng ký không validate gì, luôn trả 200

- **API:** `POST /api/register`
- **Severity:** High
- **Spec:** email phải hợp lệ + duy nhất; password ≥ 8 , có hoa/thường/số/ký tự `@$!%*?&`; thiếu/sai phải trả 400 (`api_specification.md`, FR-01).
- **SUT:** trả 200 cho mọi body: email `"not-an-email"`, password `"1"`, thiếu field, name rỗng.
- **Evidence:** M3-FR01-005...020 trong Discovery Suite (mọi case invalid đều fail vì SUT trả 200 thay vì 400).
- **Root cause:** handler register trong `server.js` không có nhánh validation nào trước `INSERT`.
- **GitHub Issue Link:** [GitHub Issue #18](#)
- **Screenshot:** [bug-reports/screenshots/bug-m3-001-register-validation.png](#)

BUG-M3-002 — FR-01: Email trùng vẫn đăng ký được (kể cả khác case)

- **Severity:** Medium
- **Spec:** email duy nhất $\rightarrow$ 409 Conflict.
- **SUT:** đăng ký lại `coupon_user@eshop.com` trả 200 (hoặc 500 nếu UNIQUE constraint của SQLite kịp chặn — thông báo lỗi thô, không phải 409 JSON theo spec). Đăng ký `Admin@eshop.com` khi đã có `admin@eshop.com` cũng 200.
- **Evidence:** M3-FR01-021 (duplicate exact), M3-FR01-H01 (case-insensitive duplicate).
- **GitHub Issue Link:** [GitHub Issue #19](#)
- **Screenshot:** [bug-reports/screenshots/bug-m3-002-duplicate-email.png](#)

BUG-M3-003 — FR-01: Content-Type không phải JSON gây crash 500

- **Severity:** Medium
- **Spec:** request không hợp lệ $\rightarrow$ 400 (hoặc 415), server không được crash.
- **SUT:** gửi body dạng `application/x-www-form-urlencoded` $\rightarrow$ `TypeError: Cannot read properties of undefined` $\rightarrow$ 500.
- **Evidence:** M3-FR01-H02.
- **GitHub Issue Link:** [GitHub Issue #20](#)
- **Screenshot:** [bug-reports/screenshots/bug-m3-003-content-type-crash.png](#)

BUG-M3-004 — FR-09: Công thức coupon percent sai hoàn toàn

- **Severity:** Critical (ảnh hưởng tiền)
- **Spec:** `discount = total_amount * discount_value / 100`.

- **SUT:** `discount = Math.floor(total_amount * (1 - coupon.discount_value))` — coi `discount_value` là hệ số nhân trực tiếp.
- **Evidence thật (probe live):** `POST /api/apply-coupon` body `{"code": "SAVE10", "total_amount": 299999}` với `SAVE10` percent 10 trả về:

```
{"success": true, "coupon_id": 11, "discount_amount": -2699991, "final_amount": 2999990}
```

dùng thành công! Giảm 10%

Discount âm -2,699,991 — khách được "giảm" thành tăng giá, hoặc nếu `discount_value` lớn thì `final` âm. Theo spec discount phải là 29,999 (làm tròn) và `final` 269,999.

- **Evidence Newman:** các case percent trong `02_Bug_Discovery_Suite/FR-09` fail vì `discount_amount` lệch hàng chục lần.
- **GitHub Issue Link:** [GitHub Issue #21](#)
- **Screenshot:** `bug-reports/screenshots/bug-m3-004-percent-formula.png`

BUG-M3-005 — FR-09: Điều kiện C3 dùng > thay vì >=

- **Severity:** High
- **Spec:** C3 — `total_amount` lớn hơn hoặc bằng `min_order_amount`.
- **SUT:** `if (total_amount > coupon.min_order_amount)` — đơn hàng đúng bằng ngưỡng bị từ chối.
- **Evidence:** M3-FR09-014 (`SAVE10` , `total` = 300000 = `min`) kỳ vọng 200, SUT trả 400 "Đơn hàng chưa đủ giá trị tối thiểu 300,000 đ...".
- **GitHub Issue Link:** [GitHub Issue #22](#)
- **Screenshot:** `bug-reports/screenshots/bug-m3-005-min-order-bva.png`

BUG-M3-006 — FR-09: Không cần đăng nhập vẫn áp được coupon (bypass C4)

- **Severity:** Critical (SEC-02)
- **Spec:** C4 yêu cầu xác thực JWT; thiếu token → 401.
- **SUT:** `POST /api/apply-coupon` không gắn middleware auth — gọi không token vẫn 200.
- **Evidence:** M3-FR09-H01 (apply `BIGBUY` không Authorization header → 200, kỳ vọng 401).
- **GitHub Issue Link:** [GitHub Issue #23](#)
- **Screenshot:** `bug-reports/screenshots/bug-m3-006-no-auth-bypass.png`

BUG-M3-007 — FR-09: Bypass giới hạn số lần dùng (C5) bằng cách bỏ user_id

- **Severity:** Critical
- **Spec:** C5 — số lần dùng còn lại của user; hết lượt → 400.
- **SUT:** block kiểm tra `uses` chỉ chạy `if (user_id)`. Omit `user_id` → không bao giờ bị chặn, dùng `VIP100` (max 2) vô hạn.
- **Evidence:** M3-FR09-H05 — omit `user_id` , kỳ vọng 400, SUT trả 200.
- **GitHub Issue Link:** [GitHub Issue #24](#)
- **Screenshot:** `bug-reports/screenshots/bug-m3-007-omit-user-id-bypass.png`

BUG-M3-008 — FR-09: IDOR — user_id do client tự khai, không đổi chiều token

- **Severity:** High (SEC-05)
- **Spec:** quota coupon gắn với user đăng nhập.
- **SUT:** body nhận `user_id` bất kỳ; user A khai `user_id` của user B → quota tính cho B, A dùng hết lượt của B (và ngược lại có thể đốt quota người khác).
- **Evidence:** M3-FR09-H02 .
- **GitHub Issue Link:** [GitHub Issue #25](#)
- **Screenshot:** `bug-reports/screenshots/bug-m3-008-idor-user-id.png`

BUG-M3-009 — FR-09: Sai thứ tự kiểm tra điều kiện (min-order trước expiry)

- **Severity:** Low/Medium (contract)
- **Spec:** thứ tự C1→C5; coupon hết hạn phải báo hết hạn.
- **SUT:** kiểm tra `total_amount > min_order_amount` **trước** khi kiểm tra `expired_at`; coupon EXPIRED với total nhỏ trả lỗi "chưa đủ giá trị tối thiểu" thay vì "đã hết hạn".
- **Evidence:** case expiry-order trong `02_Bug_Discovery_Suite/FR-09` .
- **GitHub Issue Link:** [GitHub Issue #26](#)
- **Screenshot:** `bug-reports/screenshots/bug-m3-009-error-order.png`

BUG-M3-010 — FR-09: `final_amount` âm, không clamp về 0

- **Severity:** High
- **Spec:** `final_amount = total - discount` , hợp lý phải ≥ 0 .
- **SUT:** với coupon `percent` giá trị lớn (tạo được nhờ BUG-M3-014, ví dụ `percent 1000`) → `discount > total` → `final_amount` âm.
- **Evidence:** case percent-overflow trong Discovery; kết hợp BUG-M3-004/014.
- **GitHub Issue Link:** [GitHub Issue #27](#)
- **Screenshot:** `bug-reports/screenshots/bug-m3-010-negative-final-amount.png`

BUG-M3-011 — FR-17: SEC-03 — mọi endpoint coupon admin nhận token của user thường

- **Severity:** Critical
- **Spec:** GET `/api/coupons` , POST `/api/admin/coupons` , DELETE `/api/admin/coupons/:id` chỉ dành cho admin; user thường → 403 .
- **SUT:** `authenticateToken` (`server.js` ~dòng 100-110) chỉ verify chữ ký JWT, không kiểm tra `role` . User thường:
 - GET `/api/coupons` → 200 (leak toàn bộ coupon) — M3-FR17-006
 - POST `/api/admin/coupons` → 200 (tạo coupon giả) — M3-FR17-007 , M3-FR17-H02
 - DELETE `/api/admin/coupons/1` → 200 (xoá thật SAVE10 của hệ thống) — M3-FR17-008
- **Impact:** phá dữ liệu + gian lận khuyến mãi. Đây là bug nghiêm trọng nhất được tìm thấy.
- **GitHub Issue Link:** [GitHub Issue #28](#)
- **Screenshot:** `bug-reports/screenshots/bug-m3-011-sec03-role-bypass.png`

BUG-M3-012 — FR-17: DELETE luôn trả 200, kể cả id không tồn tại / không phải số

- **Severity:** Medium
- **Spec:** id không tồn tại → 404 Not Found .

- **SUT:** DELETE /api/admin/coupons/99999 → 200 ; DELETE /api/admin/coupons/abc → 200 . Không kiểm tra affected rows.
- **Evidence:** M3-FR17-009 , M3-FR17-028 , M3-FR17-H04 .
- **GitHub Issue Link:** [GitHub Issue #29](#)
- **Screenshot:** bug-reports/screenshots/bug-m3-012-delete-always-200.png

BUG-M3-013 — FR-17: Trùng mã coupon → 500 (SQLITE_CONSTRAINT) thay vì 409

- **Severity:** Medium
- **Spec:** mã trùng → 409 Conflict với JSON lỗi rõ ràng.
- **SUT:** POST /api/admin/coupons với code đã tồn tại → 500 kèm lỗi SQLite thô (khi constraint còn hiệu lực).
- **Evidence:** M3-FR17-H05 (SAVE10 còn tồn tại → 500).
- **GitHub Issue Link:** [GitHub Issue #30](#)
- **Screenshot:** bug-reports/screenshots/bug-m3-013-duplicate-500-crash.png

BUG-M3-014 — FR-17: Tạo coupon không validate gì (14 case invalid đều 200)

- **Severity:** High
- **Spec:** validate code khác rỗng, type ∈ {percent, fixed}, discount_value > 0 (percent ≤ 100), min_order_amount ≥ 0 , max_uses_per_user ≥ 1 , expired_at hợp lệ và trong tương lai; sai → 400 .
- **SUT:** tất cả đều 200 và ghi vào DB.
- **Impact:** kết hợp BUG-M3-004 tạo coupon percent 1000 → discount âm / final âm ở FR-09.
- **GitHub Issue Link:** [GitHub Issue #31](#)
- **Screenshot:** bug-reports/screenshots/bug-m3-014-no-create-validation.png

BUG-M3-015 — FR-17: Lệch path — spec GET /api/admin/coupons , SUT chỉ có GET /api/coupons

- **Severity:** Medium (contract)
- **Spec:** endpoint liệt kê coupon của admin là GET /api/admin/coupons .
- **SUT:** GET /api/admin/coupons → 404 ; chỉ có GET /api/coupons .
- **Evidence:** M3-FR17-H01 .
- **GitHub Issue Link:** [GitHub Issue #32](#)
- **Screenshot:** bug-reports/screenshots/bug-m3-015-path-mismatch.png

BUG-M3-016 — FR-09: user_id dạng string bị từ chối 400 thiếu nhất quán

- **Severity:** Low
- **Spec:** body schema không nói rõ phải reject user_id string; nhưng SUT reject string trong khi lại cho phép omit hẳn (BUG-M3-007) — hành vi không nhất quán.
- **Evidence:** case user_id: "6" trong Discovery FR-09.
- **GitHub Issue Link:** [GitHub Issue #33](#)
- **Screenshot:** bug-reports/screenshots/bug-m3-016-user-id-string-inconsistency.png

BUG-M3-017 — FR-17: Tạo lại mã vừa xóa thành công mà không có dấu vết audit / ràng buộc

- **Severity:** Low (hardening)
- **Spec:** quản lý coupon cần nhất quán; mã đã xóa có thể được tạo lại với tham số khác và lập tức áp dụng được.
- **Evidence:** M3-FR17-008 (xóa SAVE10 bằng user token) + M3-FR17-010 (tạo lại SAVE10 `min_order_amount = 1 → 200`).
- **GitHub Issue Link:** [GitHub Issue #34](#)
- **Screenshot:** bug-reports/screenshots/bug-m3-017-delete-recreate-chain.png

Tổng hợp & Phân loại Bug (Summary & Bug Classification)

Bảng Phân loại Bug theo API và Nguồn phát hiện (AI vs Human)

Feature API	Lỗi do AI phát hiện (AI-discovered)	Lỗi do Người bổ sung (Human-discovered)	Tổng số Lỗi	Các mã Bug ID
FR-01 (Register)	1	2	3	BUG-M3-001, BUG-M3-002, BUG-M3-003
FR-09 (Apply Coupon)	5	3	8	BUG-M3-004, 005, 006, 007, 008, 009, 010, 016
FR-17 (Coupon CRUD)	4	2	6	BUG-M3-011, 012, 013, 014, 015, 017
TỔNG CỘNG	10 (58.8%)	7 (41.2%)	17 (100%)	BUG-M3-001 đến BUG-M3-017

Tóm tắt chung

- **Tổng số lỗi:** 17 bugs (4 Critical, 5 High, 6 Medium, 2 Low).
- **Phát hiện bởi AI:** 10 bugs — tập trung vào sai sót công thức, thiếu validation cơ bản, lỗi logic biên và path mismatch.
- **Phát hiện bởi Người (Human-in-the-Loop):** 7 bugs — tập trung vào các kịch bản bảo mật chuyên sâu (SEC-03 role bypass, SEC-05 IDOR, omit user_id quota bypass, Content-Type crash).
- **GitHub Issues:** Tất cả 17 lỗi đã được đăng trên repository thực tế tại <https://github.com/HCMUS-software-testing/HW06/issues> (Issue #18 đến #34).
- **Evidence thực thi:** `newman/member-3/bug-discovery-report.html` (chạy thật trên `http://localhost:3000` , reseed trước khi chạy).